

Risk Memo

Summary

A security assessment was reviewed for the bank to use a cloud-based HR platform. The vendor uses encryption strategies for all stages of the data lifecycle, they take measures to prevent unwanted access to sensitive PII data, they maintain audit logs and comply with multiple security frameworks, and have an incident response plan in place in case of a data compromise event. Although the inherent risk is high the security controls implemented by the vendor reduces the residual risk to an acceptable residual risk for operations.

Access Management

The vendor has multiple sources of access controls that would prevent unwanted access to the bank's employee data. These access controls would be an Access Context Manager that would allow configurations to allow access defined in a policy or framework. Identity and Access Management is another control to create and manage permissions within the environment. The vendor also mandates a multifactor authentication for all users.

Data Protection

For data security purposes the vendor encrypts all data types. The vendor encrypts data at rest using Advanced Encryption Standard(AES-256). Also encrypting data in transit with transport layer security and application layer transport security. They also use a Confidential Space system so that data is only visible to the workload and the owners of the data.

Monitoring and Compliance

The vendor writes audit logs that record administrative activities and access within the resource. The bank would also be able to use the vendor's Audit manager to run audits against specified compliance frameworks. These built-in compliance frameworks include NIST 800-53, SOC2, ISO 27001, PCI-DSS etc.

Incident Response

When dealing with a security incident the vendor has two different channels for communication Personalized Service Health which would be the primary source of an incident relevant to the bank, and the vendor's Service Health which is a public facing status page. During these incidents the vendor would give information on the impact, updates, relevance, workarounds, eta's.

Recommendation

Based on all of the information gathered the vendor uses mature security practices that help prevent, detect, and respond to security incidents. It is recommended that the bank use this vendor's HR platform, given that they continue security reviews and comply with security best practices.